

# PDF Tool

## Audit #6 — Reproducible Builds & Font Fidelity

Live: <https://pdftool4u.duckdns.org> (AWS EC2, Elastic IP)

Date: 17 July 2026 · Prepared for: Mukesh Kumar

OVERALL PRODUCTION READINESS

96 / 100

Series: 89 → 92 → 93 → 95 → 96. Reproducible builds closed the last engineering-debt finding; the editor's font pipeline is now verified across three PDF renderers.

## 1. Executive Summary

Two campaigns defined this cycle. First, the **pnpm migration** closed F4 — the last engineering-debt finding from the audit series: the committed lockfile is now platform-complete (Windows and Linux native binaries recorded together), every environment installs with `--frozen-lockfile`, and builds are byte-reproducible. The E2E suite grew from one to four real-browser journeys (upload, page numbers, protect/unlock, merge) and runs as a blocking CI gate.

Second, the **font-fidelity campaign**: drop-in licensed font support (server-side files, outside git, volume-mounted, gracefully degrading) driven by adversarial testing on real Uber receipts. This cycle included a shipped regression — whole-file font embedding, introduced on a misdiagnosis, produced invalid embedded fonts — which the owner's testing caught and which was then root-caused with a cross-renderer test harness (pdf.js, pdfium, poppler) built for the purpose. The final pipeline — OTF converted to TTF, subset-embedded — was verified rendering identically in all three engines before shipping. Editing robustness also improved: the server now drops characters the target font cannot draw (eliminating invisible-glyph 'phantom spaces'), and the editor repairs common text-extraction artifacts on pre-fill.

## 2. Scorecard vs. Audit #5

| Area                | Score | Δ  | Note                                                                                  |
|---------------------|-------|----|---------------------------------------------------------------------------------------|
| Architecture        | 9.5   | =  | Unchanged; drop-in font layer follows the same graceful-fallback pattern              |
| Security & privacy  | 9.5   | =  | Licensed fonts kept out of git and never served to browsers                           |
| Deployment / DevOps | 9.5   | =  | Reproducible images; fonts as volume-mounted host assets (no rebuild to add)          |
| Code quality        | 9.5   | ▲  | F4 closed at the root; phantom-dependency bug surfaced and fixed by pnpm's strictness |
| Features & UX       | 9.5   | =  | Exact-match editing on Uber documents; weight-accurate mapping ready                  |
| Testing / CI        | 9.0   | ▲▲ | 4 blocking browser journeys; cross-renderer verification methodology established      |
| Performance         | 8.0   | =  | Save round-trip 2–5 s on 1 GB — inherent to the privacy design, acceptable            |
| Documentation       | 9.0   | ▼  | July docs now trail the pnpm/fonts reality — refresh recommended (F10)                |

## 3. Findings

| #          | Severity   | Finding                                                                                               | Recommendation                                                                                      |
|------------|------------|-------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| <b>F10</b> | <b>LOW</b> | Documentation edition (July 2026) predates pnpm, the E2E gate, drop-in fonts and the TTF requirement. | Refresh the technical documentation; include the fonts-custom operational note (scp + restart api). |

|             |             |                                                                                                                               |                                                                                                                                        |
|-------------|-------------|-------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <b>F1 1</b> | <b>LOW</b>  | A fix was deployed on a misdiagnosis this cycle (whole-embed regression), shipped to production, then reverted with evidence. | Process note: for rendering-sensitive changes, run the sandbox cross-renderer harness BEFORE deploying, not after. Harness exists now. |
| <b>F1 2</b> | <b>INFO</b> | Uber Move Text Regular font file still missing — timestamp-weight edits fall back to Medium (visibly heavier).                | Owner action: obtain the file; conversion pipeline and code slots are ready.                                                           |
| <b>F1 3</b> | <b>INFO</b> | Library copies edited during the whole-embed builds carry invalid embedded fonts permanently.                                 | Owner action: delete stale test copies; documents edited from originals are unaffected.                                                |
| <b>F8</b>   | <b>INFO</b> | CARRIED: mobile/touch pass still pending (resize handles especially).                                                         | An evening with a phone.                                                                                                               |

## 4. What This Cycle Proved

- **pnpm's strictness pays immediately:** migration surfaced a real phantom dependency (undeclared @types package) that npm's hoisting had been hiding for the project's entire life.
- **Evidence-driven debugging:** the phantom-space bug was reproduced in isolation, bisected across three renderers with rendered-image proof at each step, and fixed at the root (CFF→TTF) rather than patched around.
- **The regression lesson (F11):** the one bad deploy of the cycle came from fixing a symptom before reproducing it. The cross-renderer harness that later solved it took under an hour to build — building it first would have prevented the regression entirely.
- **Defense in depth compounds:** the unglyphed-character filter, extraction cleanup, and graceful font fallbacks each guard against whole classes of future document quirks, not just the Uber case.

## 5. Verdict

**96/100.** The engineering-debt column of this project is now empty: reproducible builds, four-journey browser testing, non-root containers, stable IP, monitoring, verified privacy architecture. What remains is the same short list as last audit — mobile pass, DR drill, real domain, paid redundancy — plus a documentation refresh. The font campaign, for all its cycles, ended somewhere genuinely rare: a free web PDF editor that produces renderer-verified, letterform-exact text replacement. Recommended next: the free items (mobile pass, DR drill, docs refresh) at leisure — and real users.

---

Automated senior-engineer audit, 17 July 2026. Sixth in series (89 → 92 → 93 → 95 → 96).